SKITII PRODUCT ADMIN

4-Day Audit Log

Append-only history of who created, edited, or deleted records in Skitii Backend and the Product Admin Panel.

VERSION
1.0

DATE
August 2026

AUTHOR
Swapnil Sagvekar

CUSTOMER
Internal (Skitii Product)

SCOPE
Append-only audit history for Product Admin actions

Goal for Day 4

By end of Day 4:

- Every Product Admin **create / update / delete** (and approve / reject / block) writes an **append-only** `auditLogs` row
- Each row records **who**, **what**, **when**, **which module**, and **before / after**
- Super Admin / users with `product.audit` **view** can filter and inspect history in Skitii Admin Panel
- Nobody can edit or delete audit rows (not even Super Admin via API)
- Audit writes never fail the business action (log errors, do not roll back the mutation)

Prerequisite

Must already exist	From
Internal users with email + `userId` on JWT	10-Day RBAC Days 1–3
`me` + `PermissionsGuard`	10-Day RBAC Days 2 & 5
Module key `product.audit` in catalog	10-Day RBAC Day 1 (reserved)
Users / Roles screens	10-Day RBAC Days 6–7

Do **not** start this sprint until the 10-day handoff checklist is green. Actor identity must be a real admin user, not a shared `ADMIN` seed with no trail.

Overview

Day	Workstream	Duration
1	Schema, writer, request context; instrument Users / Roles / Permissions	1 day
2	Instrument remaining Product Admin mutations	1 day
3	Query APIs (list, filters, detail); indexes; `product.audit` view	1 day
4	Audit UI in Admin Panel + smoke + handoff	1 day

What a proper audit row contains

Field	Purpose
`_id`	Immutable id
`createdAt`	Server time (UTC)
`actorUserId`	Who did it (`users._id`)
`actorEmail`	Email snapshot (still readable if user is later renamed)
`actorRoles`	Roles at the time of the action
`action`	`create` · `update` · `delete` · `approve` · `reject` · `block` · `unblock` · `assign_role` · `set_permissions`
`moduleKey`	e.g. `product.users` , `product.institutions` , `product.music_library` , `product.blogs` , `product.podcasts`
`entityType`	e.g. `User` , `Institution` , `MusicAsset` , `Blog` , `Podcast` , `Episode` , `AdminRole`
`entityId`	Target document id
`summary`	One-line human text, e.g. `Blocked user nina@skitii.com`
`before`	JSON snapshot **before** change (`null` on create)
`after`	JSON snapshot **after** change (`null` on delete)
`requestId`	Correlation id from the HTTP/GQL request
`ip`	Client IP if present
`userAgent`	Browser / client string

Rules

- **Append-only.** No update/delete mutations on `auditLogs` . No TTL delete in v1 (index for query speed only).
- **Redact secrets.** Never store OTP codes, JWT, password hashes, or full music file binaries. Store ids, emails, status, permission flags.
- **Best-effort write.** If audit insert fails, log the error; the original mutation still succeeds.
- **Reads** require `product.audit` + **view**. Super Admin has view. There is no audit **create/edit/delete** permission — the writer is internal.

Mutations that must be audited

Must-have (Days 1–2)

Module	GraphQL / action	`action`
Users	create / update / block / unblock / assign roles	`create` `update` `block` `unblock` `assign_role`
Roles	create / update / archive role	`create` `update` `delete`
Permissions	save matrix	`set_permissions`
Institutions	`createInstitutionByAdmin`	`create`
Institutions	`approveInstitution` / `rejectInstitution`	`approve` / `reject`
Institutions	`blockUser` (institution user)	`block`
Institutions	`updateInstitution`	`update`
Devices	create / update / delete physical device	`create` `update` `delete`
Music categories	`createMusicCategory` / `updateMusicCategory` / `deleteMusicCategory`	`create` `update` `delete`
Music library	`createMusic` / `updateMusic` / `deleteMusic`	`create` `update` `delete`
Email categories	create / update / delete	`create` `update` `delete`
Email templates	create / update / delete / duplicate	`create` `update` `delete`
Inquiries	update status / fields	`update`
Blog topics	`createBlogTopic` / `updateBlogTopic` / `deleteBlogTopic`	`create` `update` `delete`
Blogs	`createBlog` / `updateBlog` / `deleteBlog`	`create` `update` `delete`
Podcast topics	`createPodcastTopic` / `updatePodcastTopic` / `deletePodcastTopic`	`create` `update` `delete`
Podcasts	`createPodcast` / `updatePodcast` / `deletePodcast`	`create` `update` `delete`
Episodes	`createEpisode` / `updateEpisode` / `deleteEpisode`	`create` `update` `delete`

Do not audit (v1)

Event	Why
Login OTP send / verify	High volume; not an admin data change. Optional stretch
List / get queries	Reads are not history of *changes*
Email send / preview	Covered by existing `email_logs` / `notification_requests`
Session readings fetch	Read-only admin inspect

Day 1 — Schema, writer, Users / Roles

Stream	Tasks	Status
Backend	Collection `auditLogs` with the fields above. Indexes: `{ createdAt: -1 }`, `{ moduleKey, createdAt }`, `{ actorUserId, createdAt }`, `{ entityType, entityId, createdAt }`	☐
Backend	`AuditService.record({...})` — single write path. Capture actor from request context (JWT `sub` + email). Capture `ip` / `userAgent` / `requestId` from interceptor or interceptor+ALS	☐
Backend	Instrument **Users** and **Roles / matrix** APIs from the 10-day sprint. `before` / `after` = lean JSON of the document (permissions = full matrix snapshot)	☐
Safety	Strip OTP/JWT fields if they ever appear. Writer swallows insert errors	☐

Deliverable: Creating a user or saving a role matrix produces one audit row. No UI yet.

Day 2 — Instrument remaining Product Admin writes

Stream	Tasks	Status
Backend	Hook `AuditService` in: `AdminService` (create/approve/reject/block/update institution), physical devices, music category + asset services, email category + template services, website inquiries update, blog topic + blog services, podcast topic + podcast + episode services	☐
Snapshots	Load `before` **before** the write. On delete, `after` is `null` and `before` is the last state. On approve/reject/block, `before.status` / `after.status` must be visible	☐
Checklist	Walk the “Must-have” table; every mutation has a test or a logged sample row in local Mongo	☐

Deliverable: Any Product Admin write from the live panel leaves a row. Queries still un-audited.

Day 3 — Query APIs

Stream	Tasks	Status
Backend	`auditLogs` list: pagination; filters — date from/to, `moduleKey`, `action`, `actorUserId` / actor email search, `entityType` + `entityId`. `auditLog(id)` detail including `before` / `after`	☐
Guards	`@RequirePermission('product.audit', 'view')`. **No** update/delete resolvers. Super Admin included via existing bypass	☐
Catalog	Enable `product.audit` in the module catalog if it was reserved-only; grant view to Super Admin (already all-true)	☐

Deliverable: GraphQL list + detail work in Playground with a limited Admin (view only) and fail without `product.audit`.

Day 4 — Admin Panel UI + handoff

Stream	Tasks	Status
Frontend	Sidebar item **Audit History** (`product.audit` view). Page `/audit`: date range, module, action, actor search. Table: time, actor, action, module, summary, entity. Row click → dialog with before/after JSON (readable key/value, not raw dump only)	☐
UX	Empty state; forbidden if no view; no edit/delete buttons. Deep link `?entityType=&entityId=` so Users/Roles can “View history” later (stretch if time)	☐
Smoke	Super Admin vs user **without** audit view. Perform: create user, block institution, update music, delete email template — all four appear with correct actor and before/after	☐

Handoff checklist

- ☐ `auditLogs` is append-only (no update/delete API)
- ☐ Create user → row with `after`, `before` null
- ☐ Block institution → `action=block`, status change in before/after
- ☐ Save role matrix → `action=set_permissions`, matrix in after
- ☐ Delete music track → `after` null, title in `before` / summary
- ☐ User without `product.audit` view: no sidebar item, GraphQL `FORBIDDEN`
- ☐ OTP / JWT never stored in `before` / `after`
- ☐ Failed audit insert does not fail `updateInstitution`

Deliverable: Product Admin has a working audit history for all admin writes.

Parallel Work View (Days 1–4)

```
Day:     1                   2                     3               4
         |
Backend  [Schema+writer+RBAC] [All other mutations] [List/detail API]
Frontend                                            [Audit page + smoke]
```

What this 4-day sprint is not

Out of scope	Note
Trial Admin / Trial Backend events	Product stack only
Auditing every tablet session start/stop	Clinical volume; not this panel
Login / OTP attempt history	Stretch
CSV export of audit	Stretch after filters work
Immutable legal WORM storage	Mongo append-only + no API delete is v1
Rebuilding RBAC	10-day plan

Checkpoint Summary

Checkpoint	Day	Expected outcome
Writer live	Day 1	Users / roles / matrix produce rows
Coverage	Day 2	All Product Admin writes produce rows
Queryable	Day 3	Filtered list + detail APIs, view-gated
Visible	Day 4	Audit page in Product Admin

Risks for 4 Days

Risk	Mitigation
Huge `before` / `after` (music metadata, templates)	Store identifiers + changed fields + small snapshots; skip file buffers
Missing a mutation	Day 2 checklist vs the must-have table; Day 4 smoke list
Audit write slows mutations	Fire-and-forget insert; do not await extra collection reads beyond one `before` fetch
RBAC not finished	Block start of this sprint
PII in snapshots	Email and institution name are expected; no OTP, no tokens, no raw uploads

Stretch (only if Days 1–3 are green)

Item	Note
“View history” on User / Institution / Music detail	Deep link into `/audit` with entity filters
Export CSV of current filter	Same columns as the table
Audit OTP login success for admin users	Separate `action=login`, no OTP value